



Agentic AI Hands-on Worksheet for Threat Modeling

Data Flow Diagram

Create the DFD for your system.

STRIDE Threat Modeling

Instructions:

For each trust boundary in your DFD, identify the potential threat type using the STRIDE categories:

- Spoofing: unauthorized entities pretending to be legitimate users or systems.
- Tampering: alteration or corruption of data or processes.
- Repudiation: denying actions or transactions, making it hard to trace activity.
- Information Disclosure: exposure of sensitive information to unauthorized parties.
- Denial of Service: disruption of service availability, preventing legitimate use.
- Elevation of Privilege: unauthorized escalation to higher levels of access.

For each control below, say which boundary it protects, which threat it stops, and how that threat would play out in THIS system. Name the real components - the vector store, the proposed tool call, the managed identity - not a generic actor.

Worksheet:

Control ID	Control Title	Modified Control Description	Trust Boundary	Threat Type	Threat Description
C-01	User authentication and prompt filtering				
C-02	Agent loop budget				
C-03	Human approval before any write				
C-04	Tool argument validation				
C-05	Per-task tool allow-list				
C-06	Grounding and citation of retrieved content				
C-07	Retrieval corpus integrity				

Control ID	Control Title	Modified Control Description	Trust Boundary	Threat Type	Threat Description
C-08	Per-agent identity and least privilege				
C-09	Scoped tokens for server-side tools				
C-10	Continuous evaluation and trace retention				

DREAD Risk Assessment

Instructions:

For each threat above, evaluate the potential impact using the following DREAD categories:

- Damage Potential: how severe would the damage be if the threat were realized?
- Reproducibility: how easy is it for an attacker to reproduce the exploit?
- Exploitability: how easy is it to launch an attack?
- Affected Users: how many users would be impacted by a successful attack?
- Discoverability: how easy is it for an attacker to discover the threat?

Score each category: 1 minimal impact (Minor), 2 moderate impact (Moderate), 3 severe impact (Major). Total them, then read the risk level off this scale:

- Minor Risk: 1-7
- Moderate Risk: 8-11
- Major Risk: 12-15

Worksheet:

Control ID	Control Title	Modified Control Description	D (Damage Potential)	R (Reproducibility)	E (Exploitability)	A (Affected Users)	D (Discoverability)	Total Score	Risk Level
C-01	User authentication and prompt filtering								
C-02	Agent loop budget								
C-03	Human approval before any write								
C-04	Tool argument validation								
C-05	Per-task tool allow-list								
C-06	Grounding and citation of retrieved content								

Control ID	Control Title	Modified Control Description	D (Damage Potential)	R (Reproducibility)	E (Exploitability)	A (Affected Users)	D (Discoverability)	Total Score	Risk Level
C-07	Retrieval corpus integrity								
C-08	Per-agent identity and least privilege								
C-09	Scoped tokens for server-side tools								
C-10	Continuous evaluation and trace retention								